

Introduction

A growing e-commerce company is expanding its business globally and plans to set up fulfillment centers and distribution hubs in cities across Vietnam. The decision of choosing on-premises allows them to keep full control over their data, protect their sensitive information, and create systems that are customized to their specific needs. Therefore, the goal is to build a secure, reliable, and scalable setup that supports their expansion by setting up separate local networks (LANs) for 4 branches to keep things secure, create a central and safe place to store data, and make sure authorized users can access the system remotely. Additionally, adding email and web servers will make it easier for employees to work together and help the company connect better with customers.

Network topology

General topology

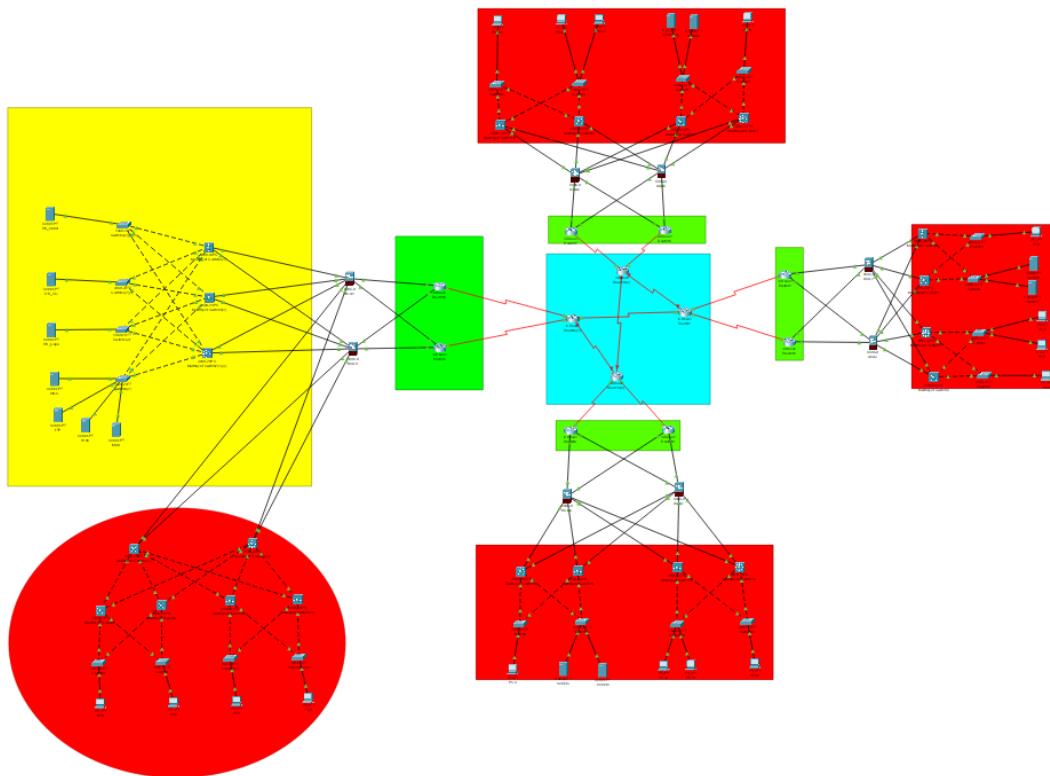


figure 2.1.1

Figure 2.1.1 illustrates the overall network topology for the e-commerce company. There are 3 branches and 1 headquarter which are distributed across different cities in Vietnam. The left side represents the headquarters located in Hanoi, and the upper, the right and the down side represent 3 other branches which are Sapa, Saigon and Hung Yen respectively. Thus, the middle part demonstrates the Internet Service Provider to provide connectivity across all the departments together.

IT infrastructure

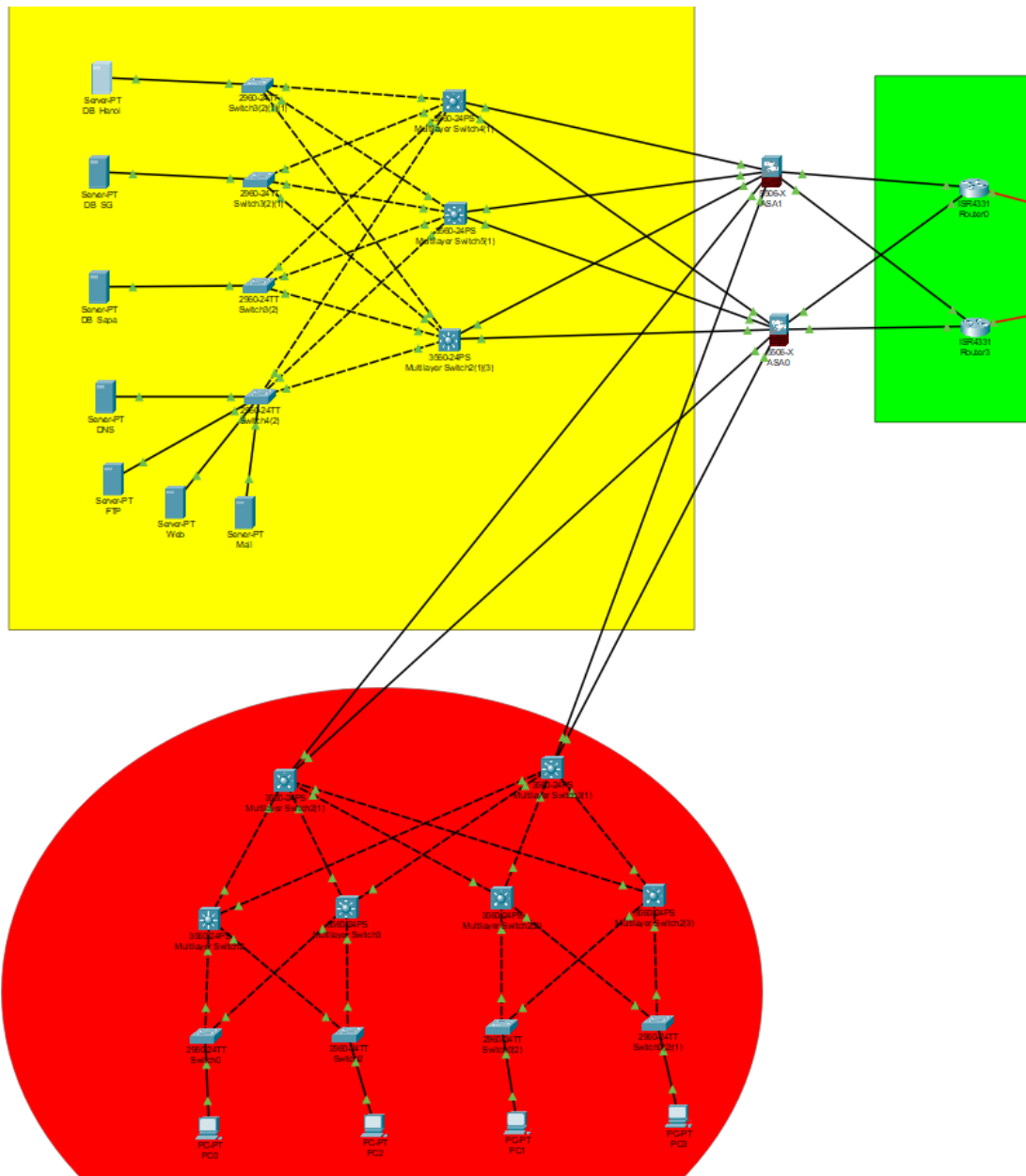


figure 2.2.1

Figure 2.2.1 illustrates the overall topology of the headquarters in Hanoi. The green zones represent the external zones, which include two routers serving as gateways for redundancy and load balancing. These routers ensure stable connectivity with the Internet Service Provider, with all incoming and outgoing traffic passing through this zone to access the internet.

The company's data center is located in the DMZ zones, acting as a buffer between the private network and the public internet. It stores customer data and hosts public-facing services like web, email, and FTP servers that require external access, while protecting the internal network from direct exposure. To host the data center for the company, spine-and-leaf architecture was chosen, offering both scalability and high availability for the network. This design ensures that the network can grow efficiently while maintaining optimal performance. In figure 2.2.1, the leaf layer includes four switches in the yellow zone. These switches distribute the traffic to the spine layer, creating many communication paths to enable load balancing and minimize latency. The spine layer, which is represented by three multilayer switches in the DMZ, serves as a central hub for managing traffic between the leaf switches. It ensures efficient data flow while preventing bottlenecks. The architecture is highly scalable because if the network expands, more multi-layer switches will be added without compromising the network performance.

Additionally, the red zone in Figure 2.2.1 highlights the internal zones, which represent the company's private network. This is where employees conduct daily operations and access the internet. As the eCommerce business grows, the demand for more employees and infrastructure increases. To meet this, a 3-tier architecture is selected for the headquarters. The top two multilayer switches represent the core layer, providing high-speed connectivity and redundancy across distribution layers. These switches ensure efficient data transfer and handle growth in the distribution layer. The four multilayer switches below represent the distribution layer, which enforces policies and enables communication between network segments. Finally, the switches and end devices at the bottom belong to the access layer.

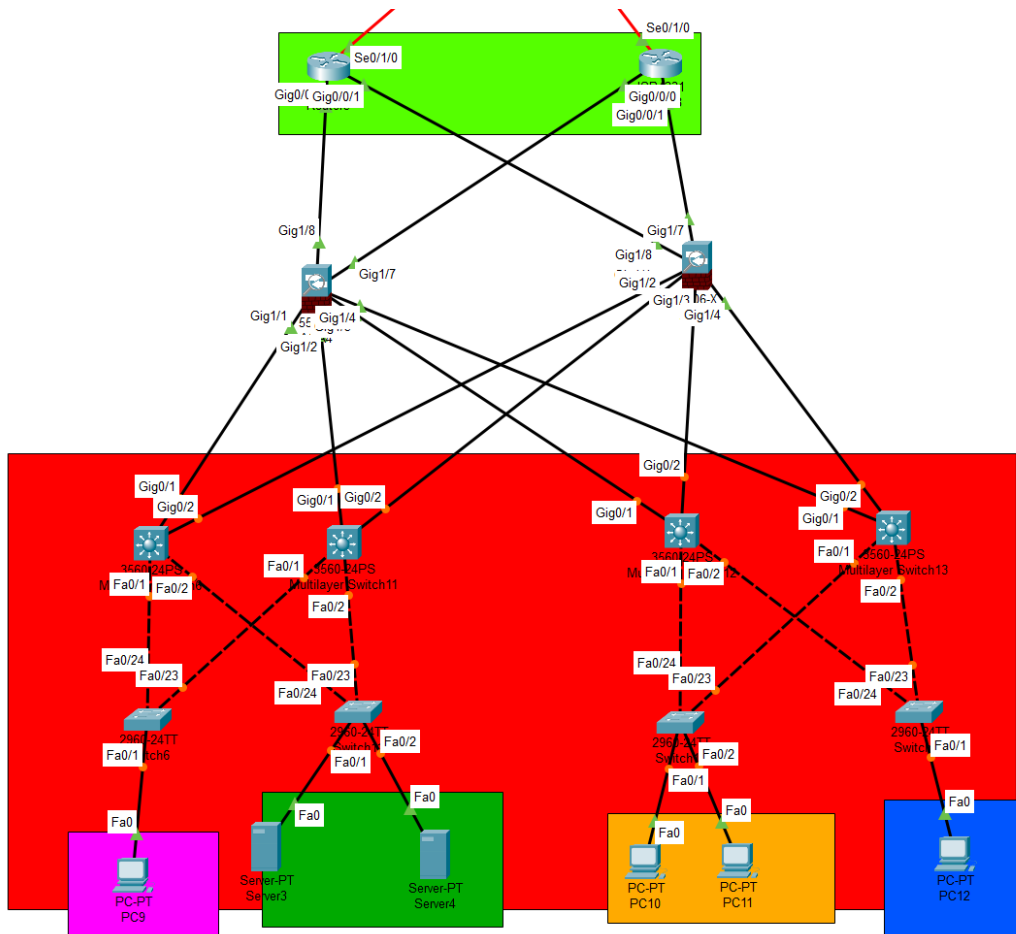


figure 2.2.2: 2-tier architecture

Next, the 3 other branches are the campus site which includes medium-sized network, so 2-tier LAN network is the suitable architecture for these branches.

Protocols configuration

Firstly, VLANs are divided in every zone and every location of the topology to separate and manage traffic flow of different departments like IT, Finance and a separate VLANs for server that save company internal.

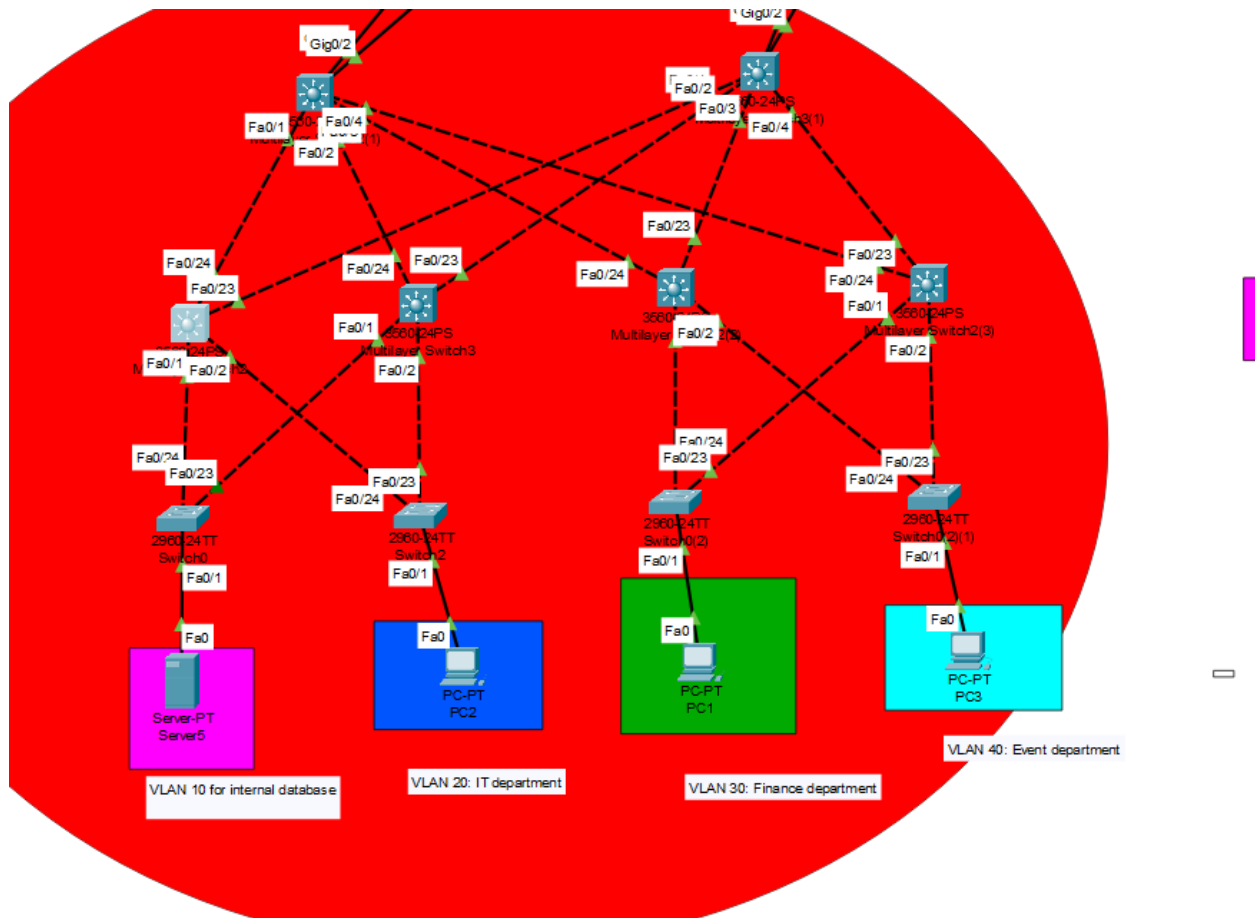


figure 2.3.1: VLANs in HQ's internal zone

Moreover, in DMZ zones, VLANs are divided for different database locations and 1 VLAN for company public servers like DNS, web, mail and file server.

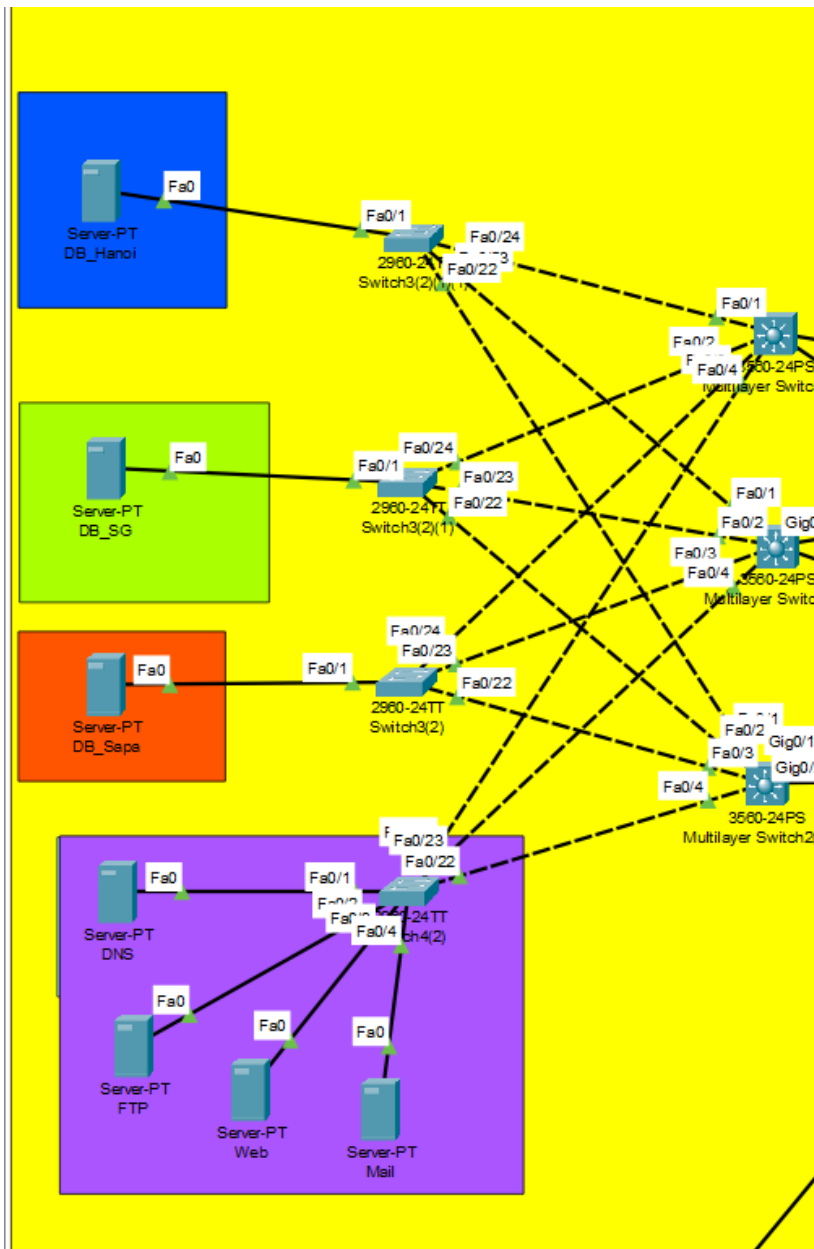


figure 2.3.2: VLANs in HQ's DMZ zone

After that, we configure Host standby routing protocols (HSRP) in the multilayer switches for not only acts as the redundant default gateway in the network, but it also for load balancing by letting 1 switch active for some VLANs and another switch active for the rest of the VLANs.

```

no ip address
shutdown
!
interface Vlan10
mac-address 00d0.d340.de01
ip address 172.16.0.12 255.255.255.240
standby version 2
standby 10 ip 172.16.0.14
standby 10 priority 105
standby 10 preempt
!
interface Vlan11
mac-address 00d0.d340.de02
ip address 172.16.0.65 255.255.255.252
!
interface Vlan12
mac-address 00d0.d340.de03
ip address 172.16.0.69 255.255.255.252
!
interface Vlan20
mac-address 00d0.d340.de04
ip address 172.16.0.28 255.255.255.240
standby version 2
standby 20 ip 172.16.0.30
standby 20 priority 95
standby 20 preempt
!
router ospf 1
log-adjacency-changes

```

figure 2.3.3: HSRP active in vlan 10 but standby vlan 20

```

shutdown
!
interface Vlan10
mac-address 00d0.bc3a.7c01
ip address 172.16.0.13 255.255.255.240
standby version 2
standby 10 ip 172.16.0.14
standby 10 priority 95
standby 10 preempt
!
interface Vlan20
mac-address 00d0.bc3a.7c02
ip address 172.16.0.29 255.255.255.240
standby version 2
standby 20 ip 172.16.0.30
standby 20 priority 105
standby 20 preempt
!

```

figure 2.3.4: HSRP active in vlan 20 but standby vlan 10

Besides that, STP is configured to block the broadcast storm in the network, especially in 2-tier or 3-tier networks. Next, for internal routing inside the headquarter and the branches, OSPF is selected due to its ability to dynamically adapt to network changes, supporting large and complex topologies. Externally, BGP is configured on the internet, enabling communication between branches and headquarters across different Autonomous System (AS) numbers. Then, Route redistribution bridges OSPF and BGP, sharing routing information between the internal and external networks. Lastly, public hosting services such as HTTP, FTP, and email (SMTP, POP3) are configured to meet the company's operational requirements, ensuring robust and scalable network performance.

Threat modelling and risk assessment

Developing threat modeling is a structured way to identify and evaluate the security risks. The process begins creating the architecture profile of the system by mapping out its data flows and components to understand the system functions and interactions. Secondly, based on the architecture profile, potential threats are identified by using frameworks or graphs like attacks tree to clearly demonstrate the possible threats can disrupt the business operation. Finally, risk assessments are conducted to evaluate the impact of the threats by reasonable scores. There are a lot of infrastructures in the network design, so for the scope of this project, some of the threats will be highlighted in this report.

Architecture profile

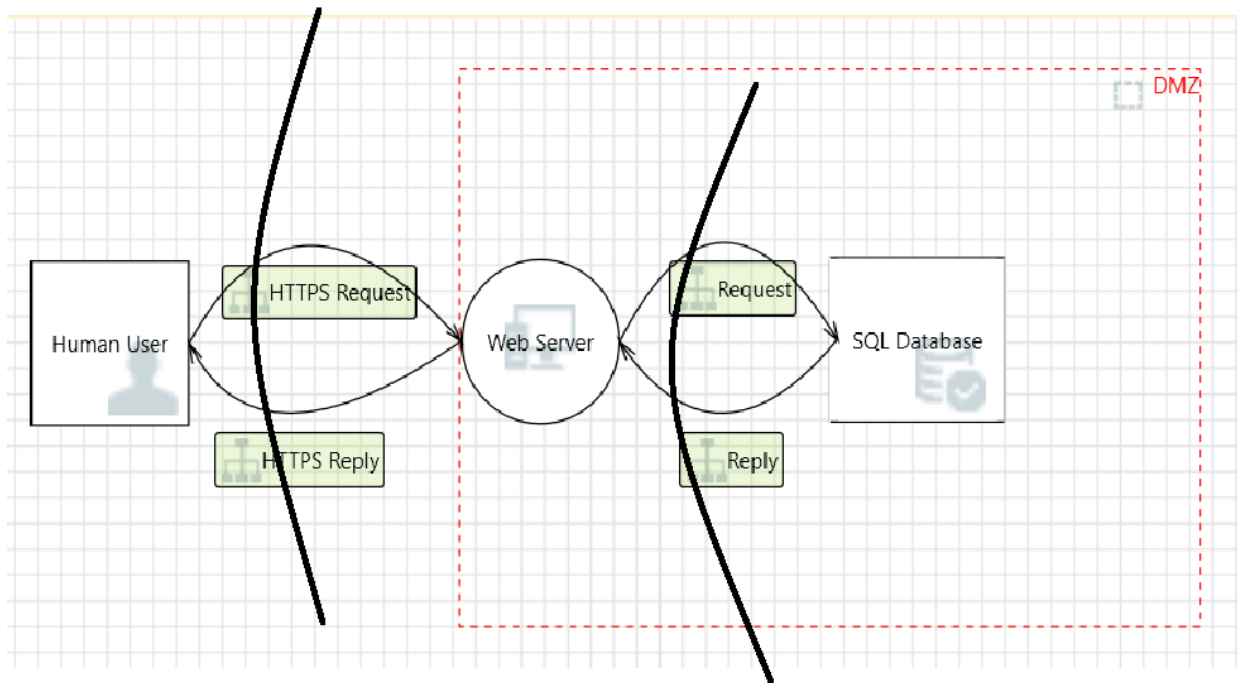


figure 3.1.1

Figure 3.1.1 illustrates the process of how web servers interact with users and get data from the database in the spine and leaf architecture in the DMZ zone. The black curve is called trust boundaries which is the lines separating zones based on its security level. Trust boundaries are critical in security because they help identify areas where extra protections, such as authentication, encryption, or validation, are needed. For instance, when a user submits input to a web application, that input must be filtered in the trust boundary between the user and the server to avoid attacks like SQL injection.

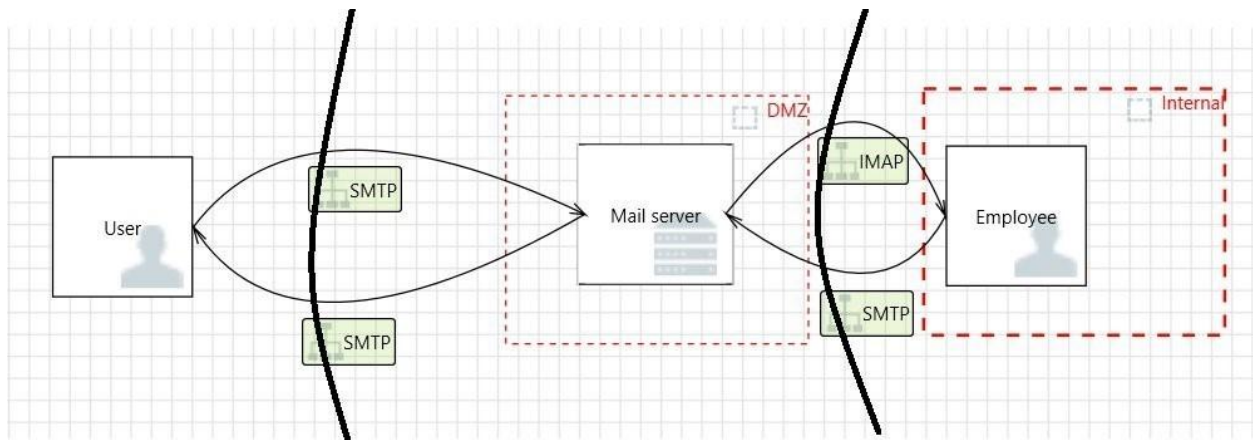


figure 3.1.2: mail server communication in different zones

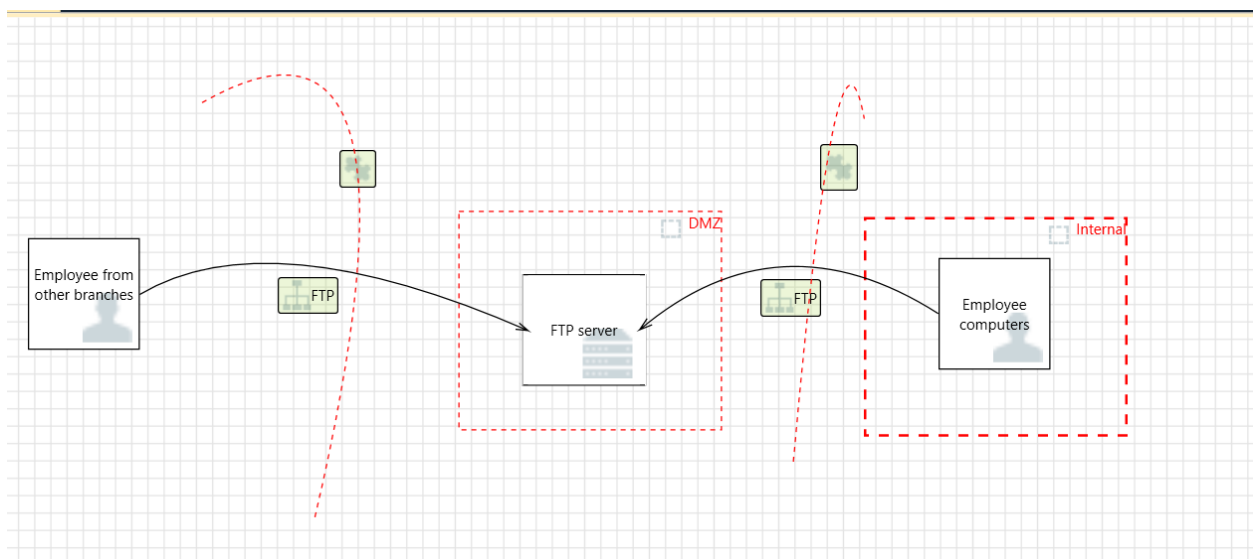


figure 3.1.3: FTP server communication in different zones

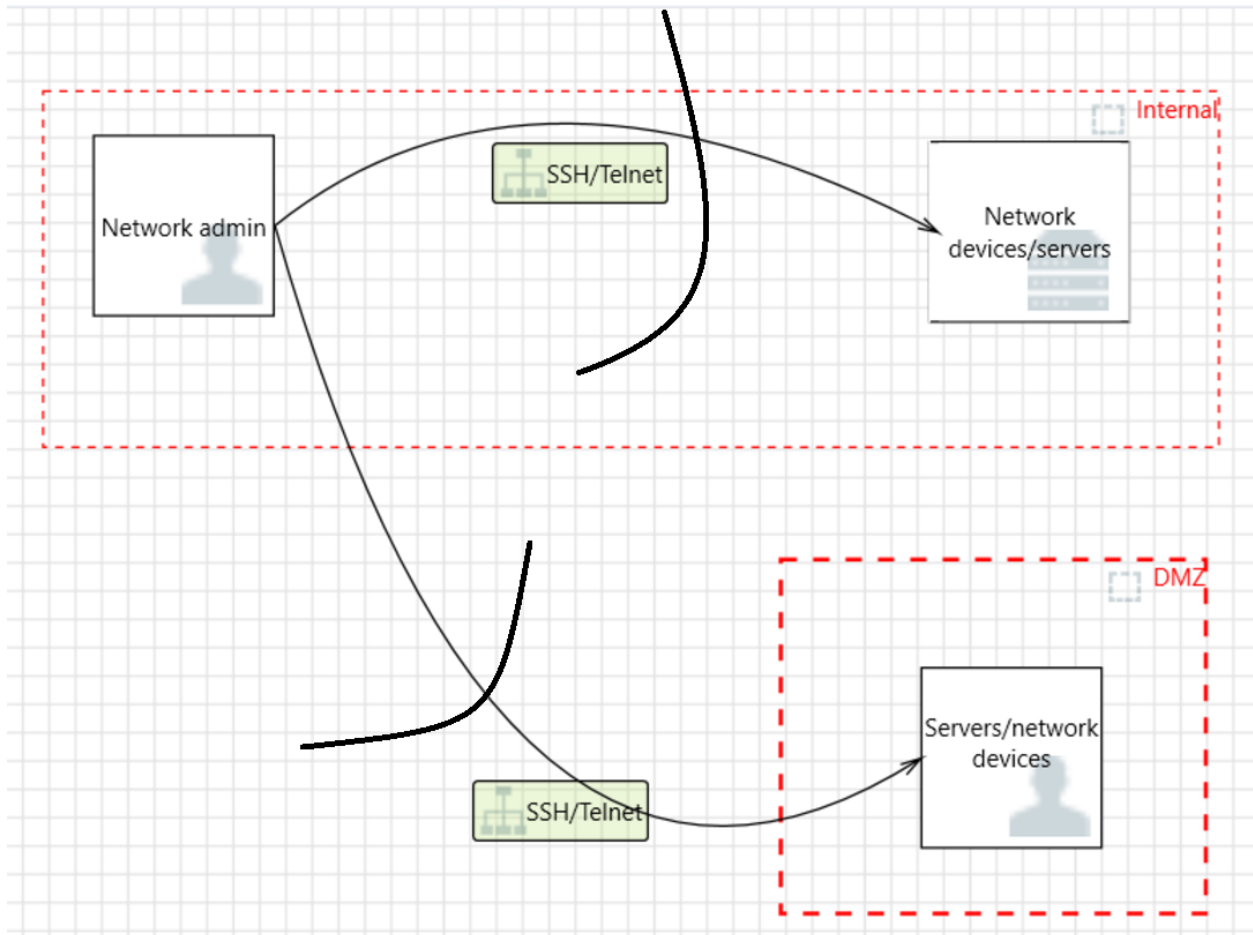


Figure 3.1.4: internal communication to configure servers or network devices

Attack tree

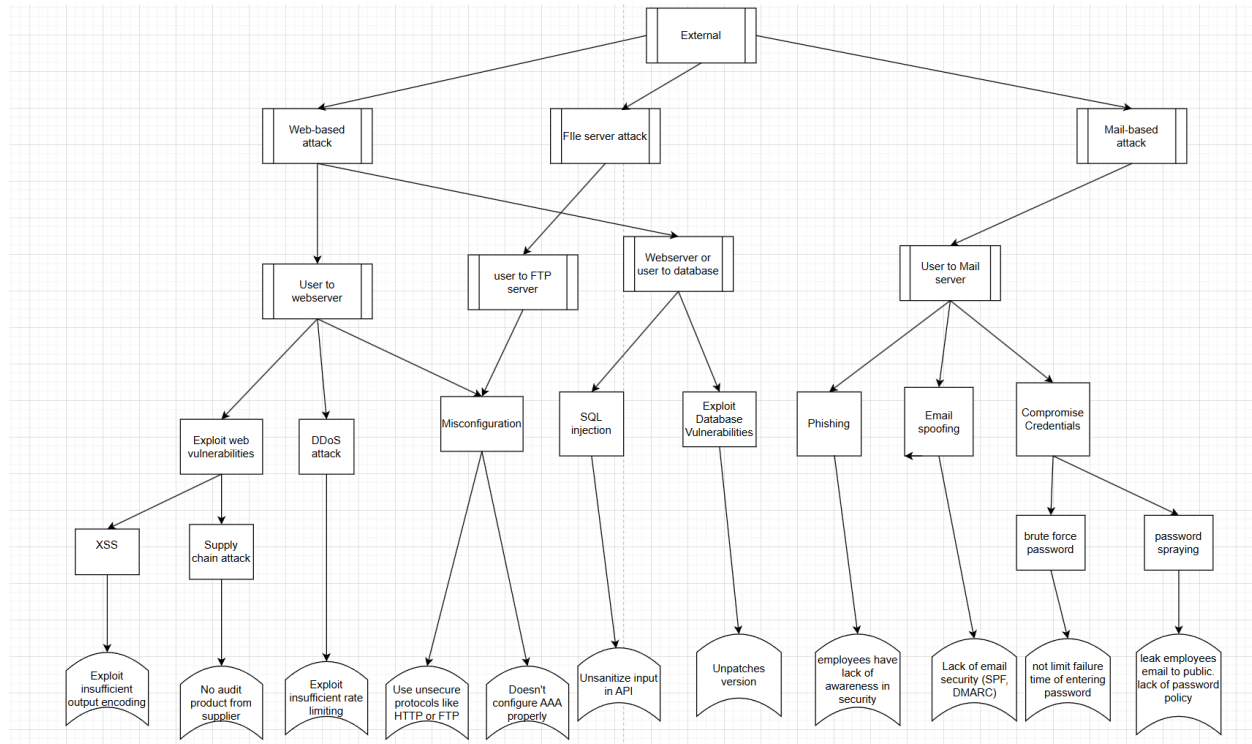


Figure 3.2.1

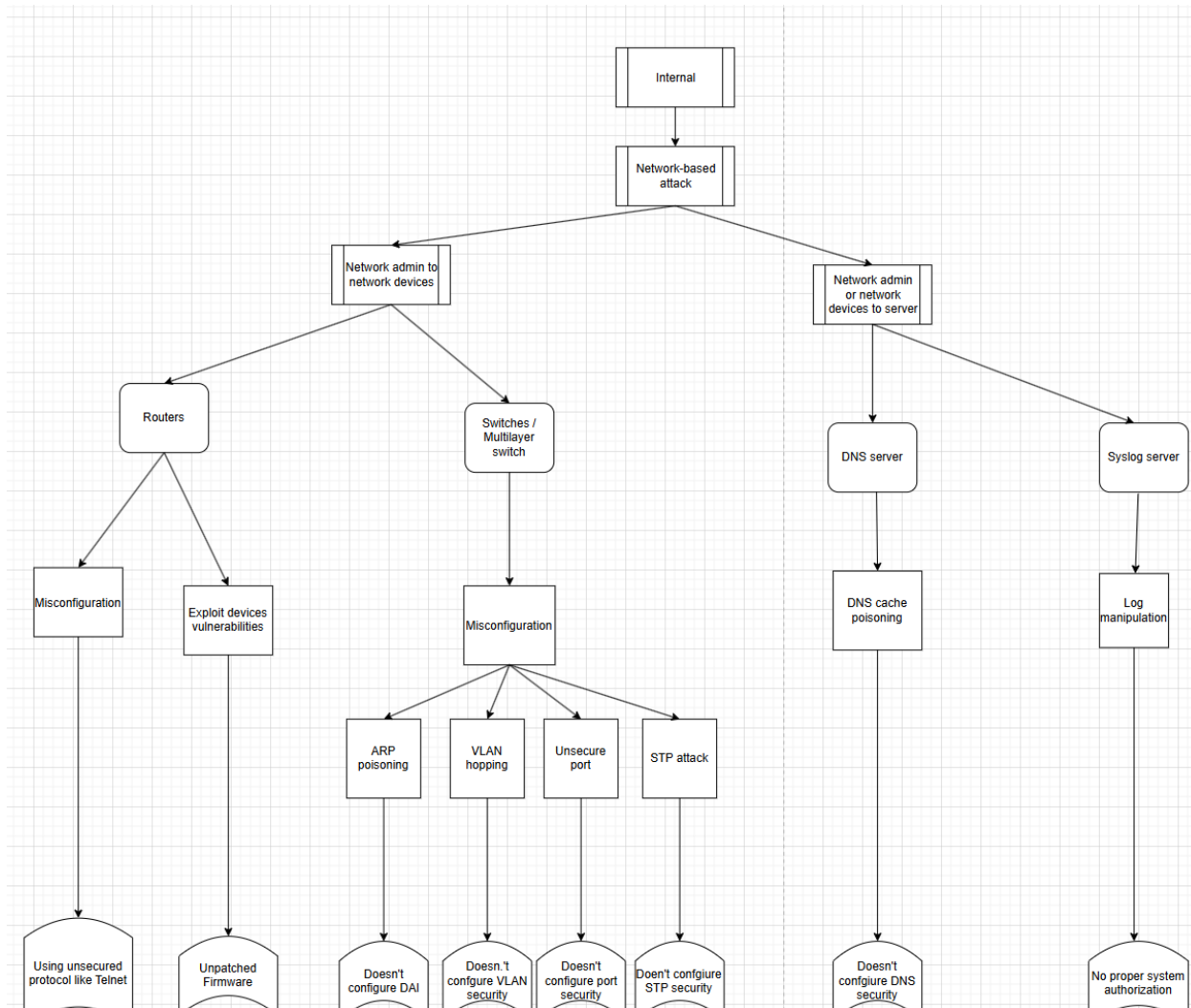


figure: 3.2.2

Figure 3.2.1 and figure 3.2.2 contain an attack tree that illustrates potential threats that can exploit the system security. The first layer shows the threats locations which are from the internal or the external. Next, the second layer shows the threat categories, and the third layer shows the communications that are highlighted in the architecture profile. After that, potential threats which can happen between those communication, are illustrated from layer 4 of the trees. Finally, the last layer displays all the vulnerabilities that can lead to those threats.

Risk assessment

Threat category	Risk description	Consequences	Likelihood	Impact	Overall risk score
External	Web-based attack like SQL injection, XSS, etc	Information breaches, damage information integrity and confidentiality	3	5	8
	DDoS	Disrupt business operation	3	4	7
	Credential attacks by credentials misconfiguration	Unauthorized access	2	4	6
	Protocols misconfiguration leading to network attacks	Disrupt the company network or damage information confidentiality	3	4	7
	Phishing, email spoofing or any email attacks	damage information confidentiality, malware execution	4	4	8
Internal	Switch/multilayer switch network attacks (STP, VLAN, ARP)	Disrupt network operation or unauthorized access	2	4	6
	Use unsecure protocol for remote access like Telnet	Credential leaks, broken information confidentiality	3	4	7
	Server log sabotage or manipulation	Clearing attack tracks, damage information integrity	3	5	8
	Exploit devices	Take control of the whole	2	4	6

	hardware or firmware vulnerabilities	devices and use it for malicious purpose			

Security configurations

To mitigate the proposed threats, several security configurations must be implemented to safeguard the network. First, insecure protocols like HTTP, SMTP, and FTP should be disabled, as they transmit data in plain text, leaving it vulnerable to interception. Secure alternatives such as HTTPS, SMTPS, and FTPS should be enabled to ensure encrypted communication.

HTTP

HTTP

☐ On ☒ Off

HTTPS

☒ On ☐ Off

File Manager

	File Name	Edit	Delete
1	copyrights.html	(edit)	(delete)
2	cscoptlogo177x111.jpg		(delete)
3	helloworld.html	(edit)	(delete)
4	image.html	(edit)	(delete)
5	index.html	(edit)	(delete)

figure 4.1.1: web server configuration

Additionally, firewalls should also be configured to block traffic on unsecured ports while permitting only secure protocols, adding an extra layer of protection.

```
!  
access-list ALLOW_HTTP_SMTP_ICMP extended permit tcp any any eq 443  
access-list ALLOW_HTTP_SMTP_ICMP extended permit tcp any any eq smtp  
access-list ALLOW_HTTP_SMTP_ICMP extended permit tcp any any eq ftp  
access-list ALLOW_HTTP_SMTP_ICMP extended permit tcp any any eq 20  
access-list ALLOW_HTTP_SMTP_ICMP extended permit icmp any any  
access-list ALLOW_HTTP_SMTP_ICMP extended deny tcp any any eq www
```

figure 4.1.2: access-list in firewall

Strong authentication practices are essential across all protocols, requiring the use of robust passwords to minimize vulnerabilities. For centralized FTP servers, user authorization should be managed with strict security models like the Bell-LaPadula model, which ensures confidentiality through role-based access control.

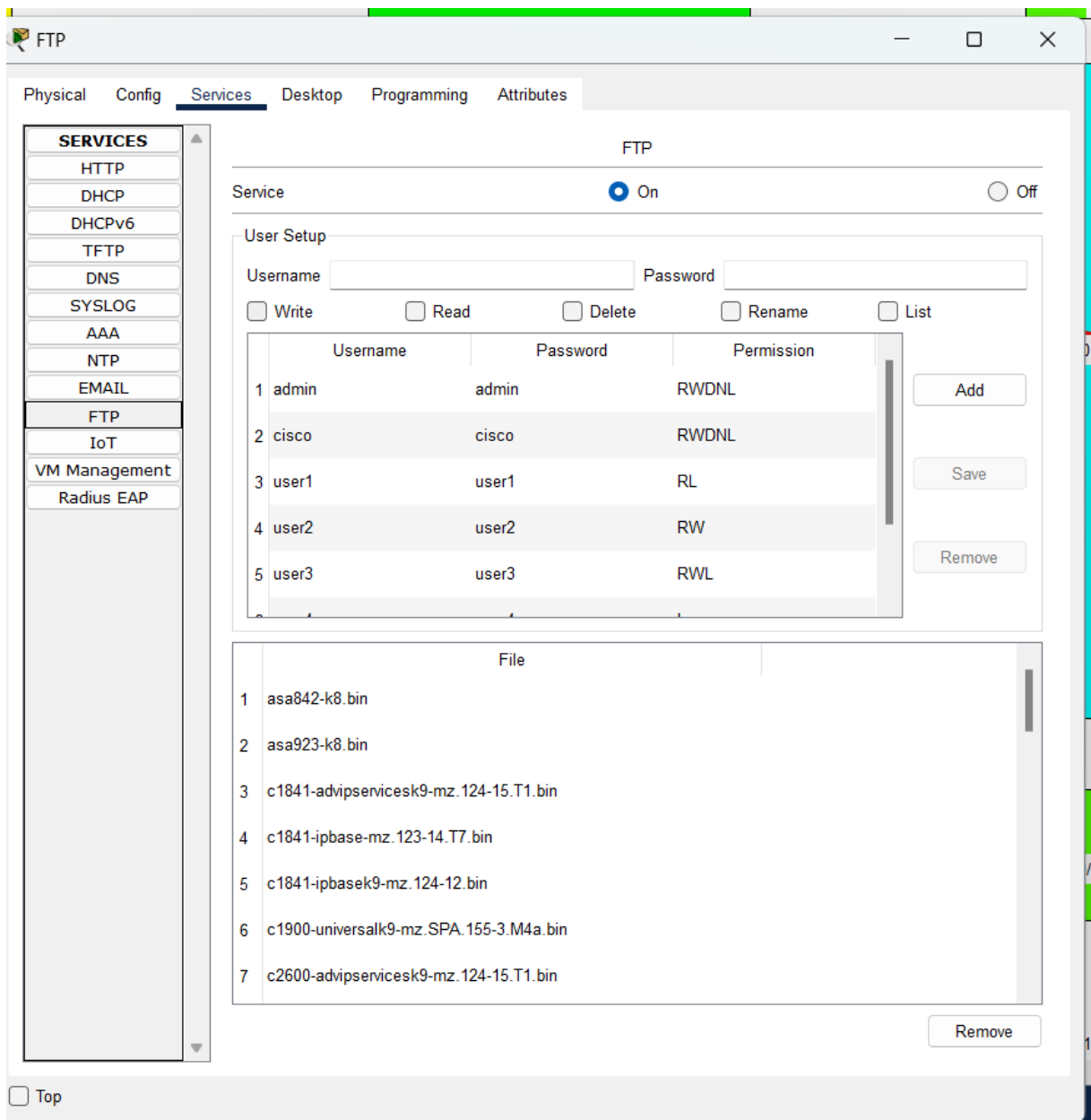


figure 4.1.3: FTP configuration

To defend against DoS or DDoS attacks, rate limiting should be applied to control the number of requests a server can handle from a single source. For companies with remote branches, site-to-site VPNs should be configured to establish secure, encrypted connections. It establishes a secure tunnel between different branch networks over the internet, ensuring that sensitive data transmitted between sites remains confidential and protected from interception.

For internal network security, configuring STP and VLAN security alongside other protocols is essential.

```
no ip dhcp snooping information option
!
spanning-tree mode pvst
spanning-tree portfast bpduguard default
spanning-tree extend system-id
!
interface FastEthernet0/1
  switchport access vlan 10
  switchport mode access
  switchport port-security
  switchport port-security mac-address sticky
  switchport port-security mac-address sticky 00D0.D342.E177
  spanning-tree portfast
  spanning-tree bpduguard enable
.
```

figure 4.1.4: portfast and bpdu guard should enable in the access mode in switches

We can see in figure 4.1.4, physical security such as port security must also be enabled to prevent unauthorized access to network devices. Furthermore, Dynamic ARP Inspection (DAI) mitigates ARP spoofing attacks by validating ARP packets against a trusted database.

```
:
interface FastEthernet0/22
!
interface FastEthernet0/23
  ip arp inspection trust
  ip dhcp snooping trust
  switchport mode trunk
!
interface FastEthernet0/24
  ip arp inspection trust
  ip dhcp snooping trust
  switchport mode trunk
!
```

Figure 4.1.5: arp inspection and dhcp snooping are configured

For secure management access, implementing AAA with SSH ensures secure access control, detailed logging of user activities, and encrypted remote management, protecting credentials from interception. In this context, unsecured protocols like Telnet should be disabled.

```
:  
!  
!  
aaa new-model  
!  
aaa authentication login SSH-LOGIN local  
aaa authentication enable default enable  
!  
!
```

Figure 4.1.6: AAA authentication

```
!  
line vty 0 4  
  login authentication SSH-LOGIN  
  transport input ssh  
line vty 5 15  
  login authentication SSH-LOGIN  
  transport input ssh  
,
```

Figure 4.1.7: SSH configuration

Finally, integrating a Syslog server enables centralized logging and monitoring of security events across the network, providing real-time insights and assisting in incident response.

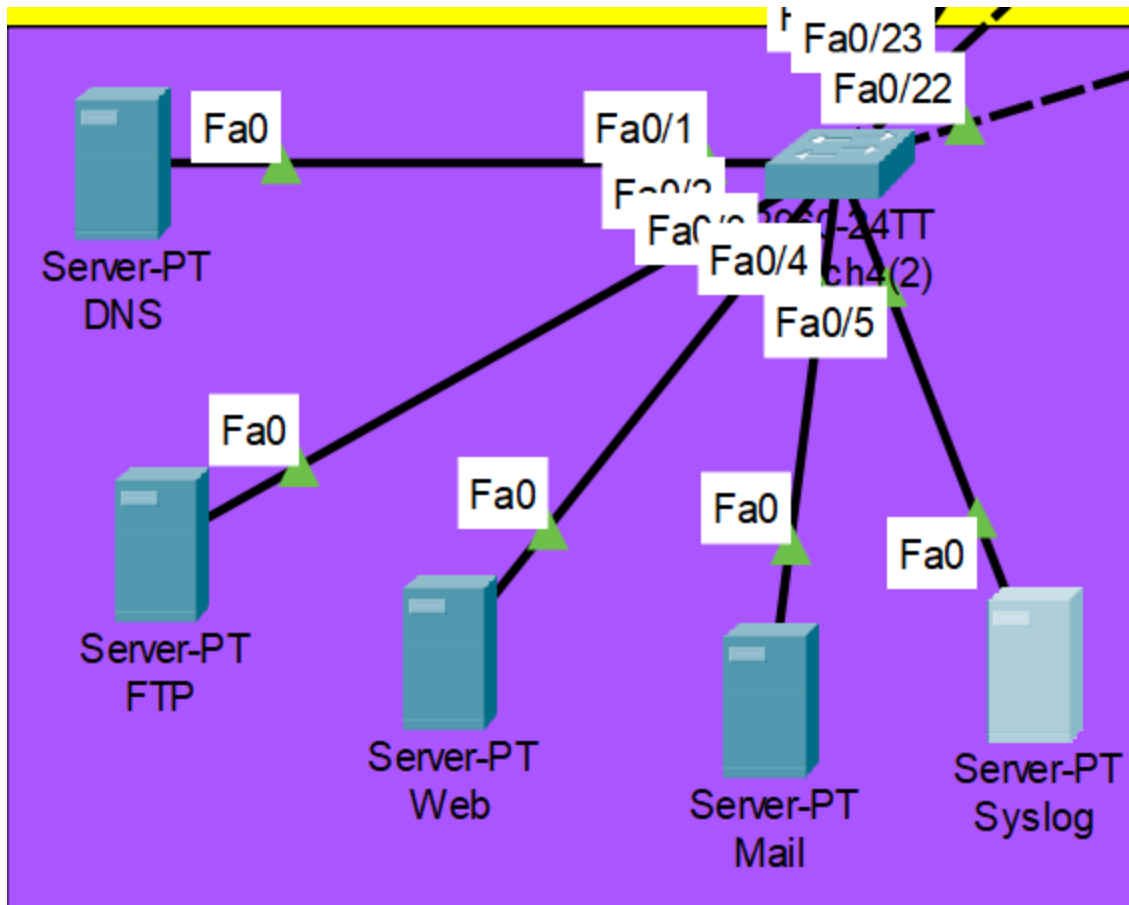


figure 4.1.8: syslog server is added

Conclusion

In conclusion, this project provides a comprehensive on-premises solution to support the company's global expansion. By establishing secure networks, centralized data storage, and reliable communication systems, the proposed infrastructure ensures efficiency, scalability, and data protection. This setup not only addresses the company's operational needs but also enhances its competitive edge in the e-commerce industry. With this robust system in place, the company will be well-prepared to manage growth and maintain smooth operations.

Word count: 1584

**Note: PLEASE make sure that you wait at least for 2 mins for the packet tracer file to work*